

Vulnerability Scanning

CompTIA PenTest+ (PT0-003)

Domain: 3.0: Vulnerability Discovery and Analysis

Objectives:

- 3.1: Given a scenario, conduct vulnerability discovery using various techniques.
- 3.2: Given a scenario, analyze output from reconnaissance, scanning, and enumeration phases.

Video Overview

This video will provide an overview of vulnerability scanning, explaining its purpose and how it fits into the broader context of penetration testing. You will learn about various considerations for performing scans, including scheduling, targeting, and handling different system types. The video also covers the distinction between credentialed and non-credentialed scans and introduces methods for automating the scanning process. This material is important for students pursuing certification or careers in IT as it covers fundamental techniques used to identify security weaknesses in systems and networks.

Key Topics Covered

- **Vulnerability Scan Definition:** Scanning a system or network for known vulnerabilities, emphasizing the importance of updated scanners.
- **Scanner Customization:** Scheduling scans (daily, weekly, once), avoiding production hours, and customizing settings for client environments.
- **Vulnerability Scanners:** Examples include Nessus, OpenVAS, and Acunetix.
- **Protocol-Specific Scans:** Targeting scans by networking protocols (TCP, UDP) and application protocols (HTTP, SMTP).
- **Network Topology Considerations:** Defining IP ranges, CIDR blocks, or domain names for targeted scanning.
- **Bandwidth Limitations and Query Throttling:** Managing scan traffic to prevent network congestion and maintain availability.

- **Fragile and Non-Traditional Assets:** Identifying and excluding systems like Industrial Control Systems (ICS), SCADA, and Industrial Internet of Things (IIoT) devices, or specialized medical equipment from automated scans.
- **Specialized Scan Types:** Host-based scans, secrets scanning, wireless scanning (SSID, channel, signal), and various application scans (DAST, IAST, SCA, SAST, IaC, source code, mobile).
- **Post-Scan Analysis and Remediation:** Reviewing reports, analyzing vulnerability lists, verifying findings (true positives vs. false positives), and selecting suitable exploits (Exploit-DB, Searchsploit, EPSS).
- **Credentialed vs. Non-Credentialed Scans:** Understanding the difference between external (non-credentialed) and internal (credentialed) perspectives for comprehensive security assessment.
- **Automation of Vulnerability Scanning:** Using GUI tools or scripting with command-line options and APIs for efficient and repeatable scans, including tools like TruffleHog and PowerSploit.

Student Notes Section